SİBER GÜVENLİK MÜHENDİSLİĞİ EĞİTİMİ-2026

HAFTA 4: Hedefi Tanıma ve Mantık Hataları (Web Recon & IDOR)

28 ŞUBAT 2026

BETÜL ZEHRA AKSU

BÖLÜM A

1.Web Anatomisi: HTTP Protokolü

200: Sunucu başarıyla çalıştı, her, giriş başarılı olmuştur.

302: Sunucu geçici olarak başka bir yere yönlendirir.

401: Siteye girebilmek için sunucu kimlik doğrulaması istiyor.

403: Sunucu giriş yapacağımız siteyi yasaklamıştır.

500: Sunucu tarafından beklenmedik bir hata olduğunu görürürüz.

2. Kimlik ve Yetki: "Sen Kimsin?"

Cookie, Session ve Token: Session , sunucu tarafından saklanırken Cookie tarayıcı tarafında saklanır; Token ise sunucusuz bir yöntemdir , tüm giriş bilgileri size paket halinde verilir. Session seni veri tabanında bilgileri saklar ,Cookie senin bilgilerinin sendeki hali Tokenda giriş yaptığında sendeki bilgilerle veri tabanındaki bilgilerin eşleştiği anlamına gelir böylece her giriş yaptığında aynı kişi olduğunu hatırlar.

Authentication vs Authorization: Authentication ,kimlik doğrulamadır sisteme giriş yaptığımızda bilgilerimizin eşleştirdiğimiz kısımdır.Authorization , yetkilendirmedir. Başkalarının mesajlarını okumak Authorizationın zafiyetidir.

3. Zafiyet Mimarisi: IDOR

IDOR'u kapı anahtarı gibi açıklayabiliriz ,sizin evinizin kapısının anahtarı sadece sizin kapınızı açmıyor başka evlerin kapılarınıda açıyor işte buna IDOR denir. Sistemde herhangi bir açık bırakmamalıyız ki evimize başkası girmesin Authorization (yetki kontrolü) yapmalıyız.

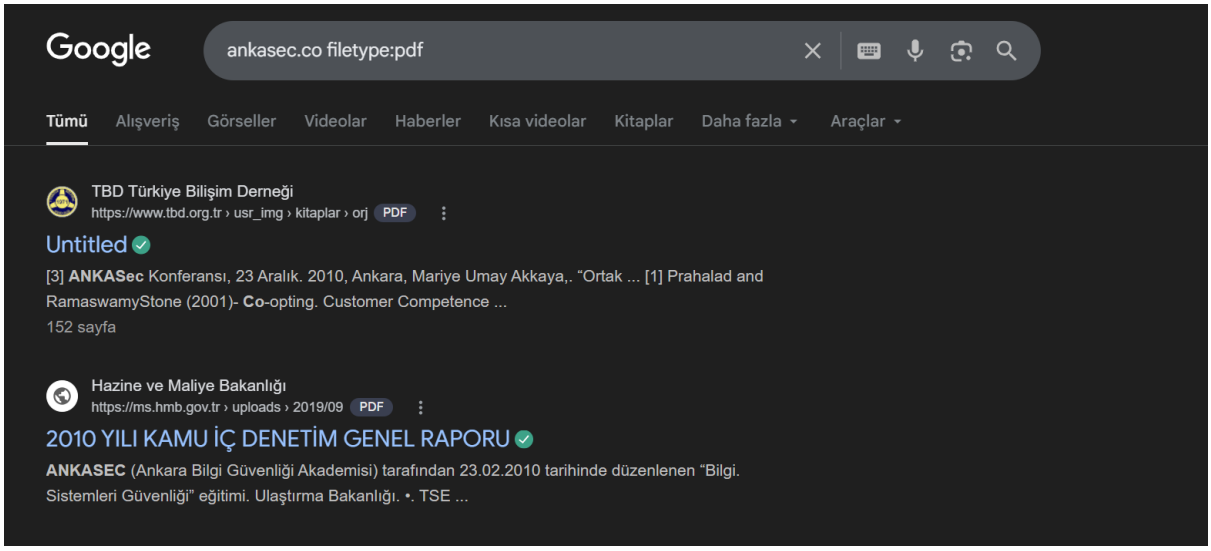
BÖLÜM B

Görev 1: İnternetin Röntgeni (TryHackMe)

User-Agent, ; siteye hangi tarayıcı, hangi cihazı kullanarak giriş yaptığımızı söyler. Host ise URL kısmında hangi siteye giriş yaptığımızı gösteren bölümdür.

Görev 2: Google Dorking (Açık Kaynak İstihbaratı)

Site:ankasec.co file:pdf = sitedeki pdfleri bulmamızı sağlar.



(ankasec.co sitesindeki pdfleri göstermesini istedim ama yokmuş)

Site:ankasec.co inurl:admin = web adresinde admin olan sayfaları sıralar.

Site:ankasec.co ext:sql = Sitenin veri tabanı dökümlerini arar.

BÖLÜM D

1.IDOR'un Gerçek Hayat Etkisi (Impact)

Sağlık verileri özel bilgiler olduğundan idari para cezası olarak şirketin yıllık cirosunun %4'üne kadar para cezası verilir.Ayrıca hastaların şirkete manevi tazminat açma hakkıda bulunmaktadır.Marka itibarı eskisi kadar güven verici olmaz , insanların şirketi kullanma oranlarında ciddi miktarda düşüş gerçekleşebilir.Eğer raporlayacak olsaydım kritik risk seviyesinde derdim.

2. Güvenin Bedeli (Zero Trust):

Kullanıcıdan gelen girdiye güvenmek bir hatadır. Bunu engellemek için arka planda dolaylı nesne referansı , kimlik mülkiyet doğrulama, merkezi yetkilendirme matrisi kontrol mekanizmalarını eklerdim.